MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 019 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · CMMC LEVELS

The CMMC Levels Are Not a Ladder, and Only One Requires a Pen Test

Level 1, 2, and 3 test different things on different clocks. Only one requires a penetration test - here is which, and why the other two do not.

BY **MACTECH SOLUTIONS**

READING TIME · 4 MIN

CMMC · NIST-800-171 · PENETRATION-TESTING · DEFENSE-CONTRACTING

Contractors talk about CMMC Level 1, 2, and 3 as though they were floors in the same building - clear a bar, move up, repeat with a harder bar. They are not. Each level asks a different question, hands the answer to a different assessor, and puts a different kind of test in front of you. Conflating them is how a program either buys a penetration test it does not need or misses the one it does.

FIELD COPY
ISSUE Nº 019
CMMC

Level 1 is a checklist, not a program

Level 1 covers the 15 basic safeguarding requirements in FAR 52.204-21 - the baseline for handling Federal Contract Information, not Controlled Unclassified Information. No third party is involved. A senior official inside the company scores the 15 requirements and self-attests annually, and that affirmation is the entire mechanism - there is no assessor to disagree with before the representation goes to the government.

That simplicity is also the trap. Self-attestation moves the risk onto the person who signs, not off the company, and a rushed Level 1 affirmation carries the same False Claims Act exposure as a rushed Level 2 one. The bar is lower. The consequence of getting it wrong is not.

110

NIST SP 800-171 REQUIREMENTS A LEVEL 2 PROGRAM IS SCORED AGAINST - THE SAME 110 LEVEL 3 IS BUILT ON TOP OF

Level 2 is where the number lives

Level 2 is the tier built for Controlled Unclassified Information, and it is scored against all 110 requirements in NIST SP 800-171 using the DoD's 5/3/1 weighted methodology - the arithmetic behind the SPRS score that ends up in a contracting officer's hands.

Who checks the scoring depends on what the contract touches. A contracting officer can designate a program as eligible for self-assessment, or as requiring certification by a C3PAO - a Certified Third-Party Assessment Organization - based on how critical the information is to national security. Both paths score the same 110 requirements. Only one puts an independent assessor's judgment between your SSP and your SPRS submission.

◆ **"TEST," TWO MEANINGS**

NIST 800-171A's assessment procedure uses "test" to mean checking that a setting is actually in effect - pulling a configuration screen, not attacking it. That is not a penetration test, and Level 2 does not require the second kind. Worth having ready before a vendor sells you one you do not need.

Level 3 adds requirements Level 2 never asked for

Level 3 does not raise the bar on the same 110 requirements - it adds a further set of enhanced requirements pulled from NIST SP 800-172, on top of everything Level 2 already covers, for the smallest population of programs handling the DoD's highest-priority CUI. The assessment is run by the Defense Industrial Base Cybersecurity Assessment Center, DIBCAC, a government body rather than a commercial C3PAO. Level 3 is where "advanced persistent threat" stops being a phrase in a briefing and starts being the actual threat model the enhanced requirements were written against.

The penetration test is a Level 3 requirement, not a Level 2 assumption

This is the confusion that costs contractors money in both directions. NIST SP 800-172 includes an enhanced requirement, commonly cited by its working number 3.12.1e, that calls for periodic penetration testing - an independent team simulating real adversary tradecraft against the system, on a defined cadence. That requirement exists at Level 3. It does not exist at Level 1, and it does not exist at Level 2.

A NIST 800-171 assessment tests whether a control is implemented. A penetration test tests whether it survives contact with someone trying to break it. CMMC asks the first question at every level and the second only at the top one.

A Level 2 program can still end up needing a pen test - not because CMMC requires it, but because a prime's flow-down clause does, or because a security-conscious buyer asks for one as a condition of the subcontract. That is a contractual requirement wearing a compliance requirement's clothing, and the two are worth telling apart before you write a check for one you were never actually asked for by the assessment itself.

Where a program rehearses before either one

The honest use case for adversarial testing below Level 3 is not the assessment. It is finding out what an attacker would find before an assessor, a prime's security team, or an actual adversary does. That is the role MacTech's own Cyber Range plays inside the platform estate - an environment built for training and validation, where a program can run realistic testing and control exercises against its own posture without the exercise happening on production systems handling live CUI.

We are not going to oversell it in this piece. This article names what the Range is for, not a feature-by-feature account of it - a fuller platform spotlight, with the specifics an operator would actually want, belongs in its own issue. What is true today: for a Level 2 program bracing for a C3PAO assessment, or a Level 3 program with an actual 3.12.1e requirement on the calendar, rehearsing in an environment built for exactly that is cheaper than finding the gap live. Talk to a director if you are trying to work out which of the three questions in this piece actually applies to your contract. ◆◆